



FUNDAÇÃO ESCOLA TÉCNICA LIBERATO SALZANO VIEIRA DA CUNHA

Detecção de mudanças maliciosas em ferramentas do Model Context Protocol (MCP)



Pesquisadores: Davi Girardi Padilha e Pedro Henrique Astolfi Gonçalves
Orientador: Anderson Jean de Farias
Coorientador: Murilo Padilha Miorim



METODOLOGIA

DESENHO EXPERIMENTAL

A pesquisa foi realizada em ambiente controlado, utilizando ferramentas MCP simuladas. Cada cenário apresenta duas versões da mesma ferramenta: uma versão previamente aprovada e uma versão atual. Antes dos testes, foi definido um gabarito indicando se a alteração deveria ser permitida ou bloqueada.

Foram preparados 90 cenários, divididos em três grupos de 30 casos: um núcleo interno controlado, destinado à comparação entre as estratégias, e dois grupos baseados em casos de ataque documentados nas pesquisas MCPTox e Connor, voltados respectivamente às superfícies de metadados e código. Os casos incluem ausência de mudança, atualizações benignas e alterações perigosas explícitas ou sutis.

COMPOSIÇÃO DOS CENÁRIOS

Conjunto	Origem e construção	Análise
N-INT	Cenários elaborados com base no MCPSecBench, que reúne ferramentas maliciosas e cenários de ataques ao MCP. Cada alteração é representada na interface, no código e na combinação de ambos.	C1 • C2 • D
MCPTox	Cenários adaptados do MCPTox, benchmark que estuda a inserção de instruções maliciosas nas descrições de ferramentas MCP reais.	C1 — Interface
Connor	Cenários elaborados com base no dataset Connor, que reúne ataques em ferramentas com descrições legítimas e código malicioso.	C2 — Código

EXECUÇÃO E MÉTRICAS

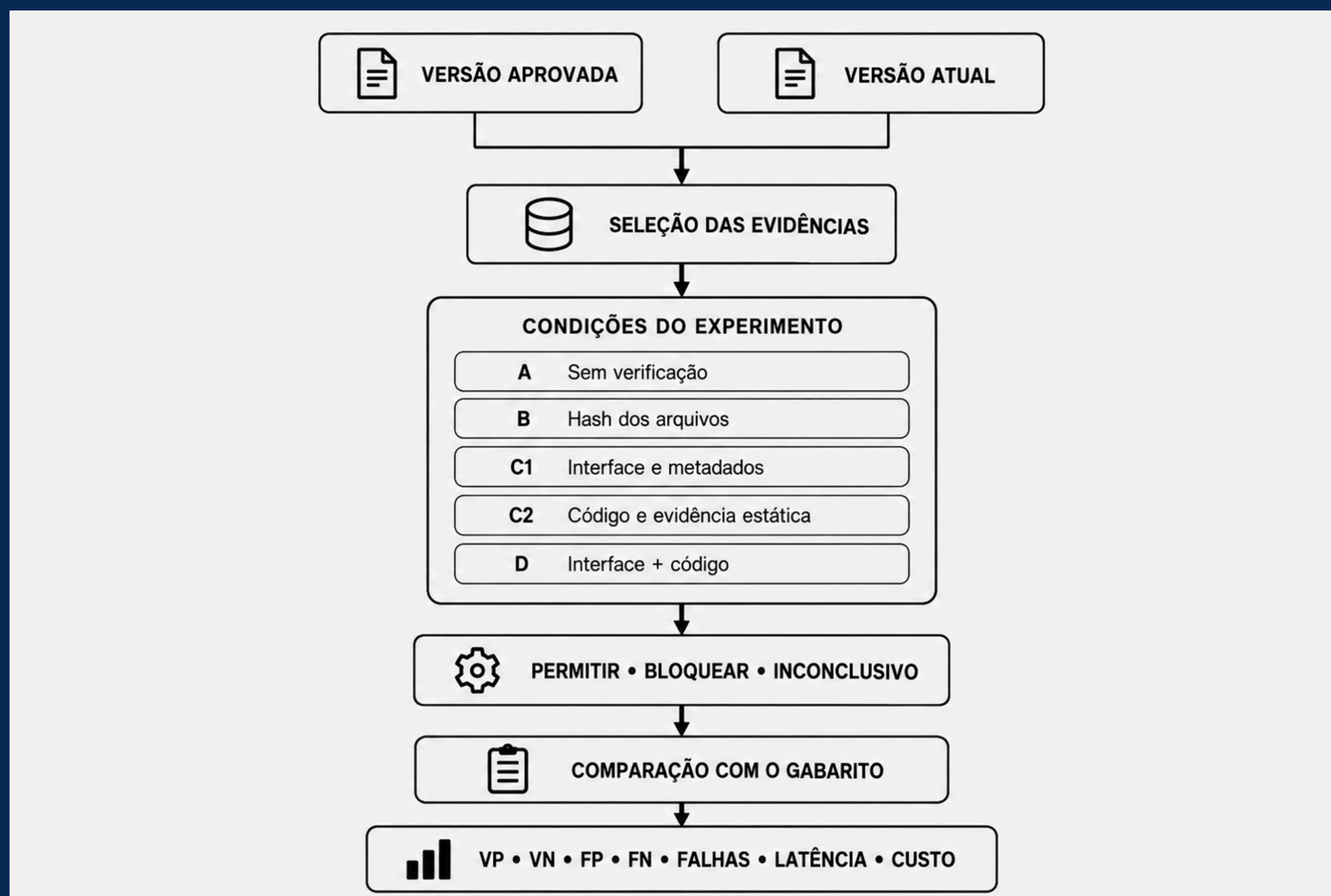
- Execução automatizada: um programa em Python apresentou a cada estratégia somente as evidências correspondentes à sua condição, sem revelar o gabarito.
- Abrangência dos testes: os 90 cenários foram avaliados por oito configurações de modelos locais e em nuvem, com duas repetições para cada combinação aplicável.
- Resultados registrados: foram armazenados decisão, justificativa, falhas, latência, consumo de tokens e custo.
- Métricas: as respostas foram avaliadas por verdadeiros e falsos positivos e negativos, respostas inconclusivas, falhas, precisão, recall e F1-score.

90 CENÁRIOS • 8 CONFIGURAÇÕES • 2 REPETIÇÕES • 2.400 AVALIAÇÕES

DESENVOLVIMENTO DO AMBIENTE EXPERIMENTAL

O ambiente experimental foi desenvolvido em Python para automatizar a preparação, execução e registro dos testes, com cenários e gabaritos armazenados em JSON. O executor seleciona as evidências de cada condição, consulta os modelos, valida as respostas e registra decisões, justificativas, falhas, latência, tokens e custo.

FLUXO DO EXPERIMENTO



Fonte: Os autores (2026).

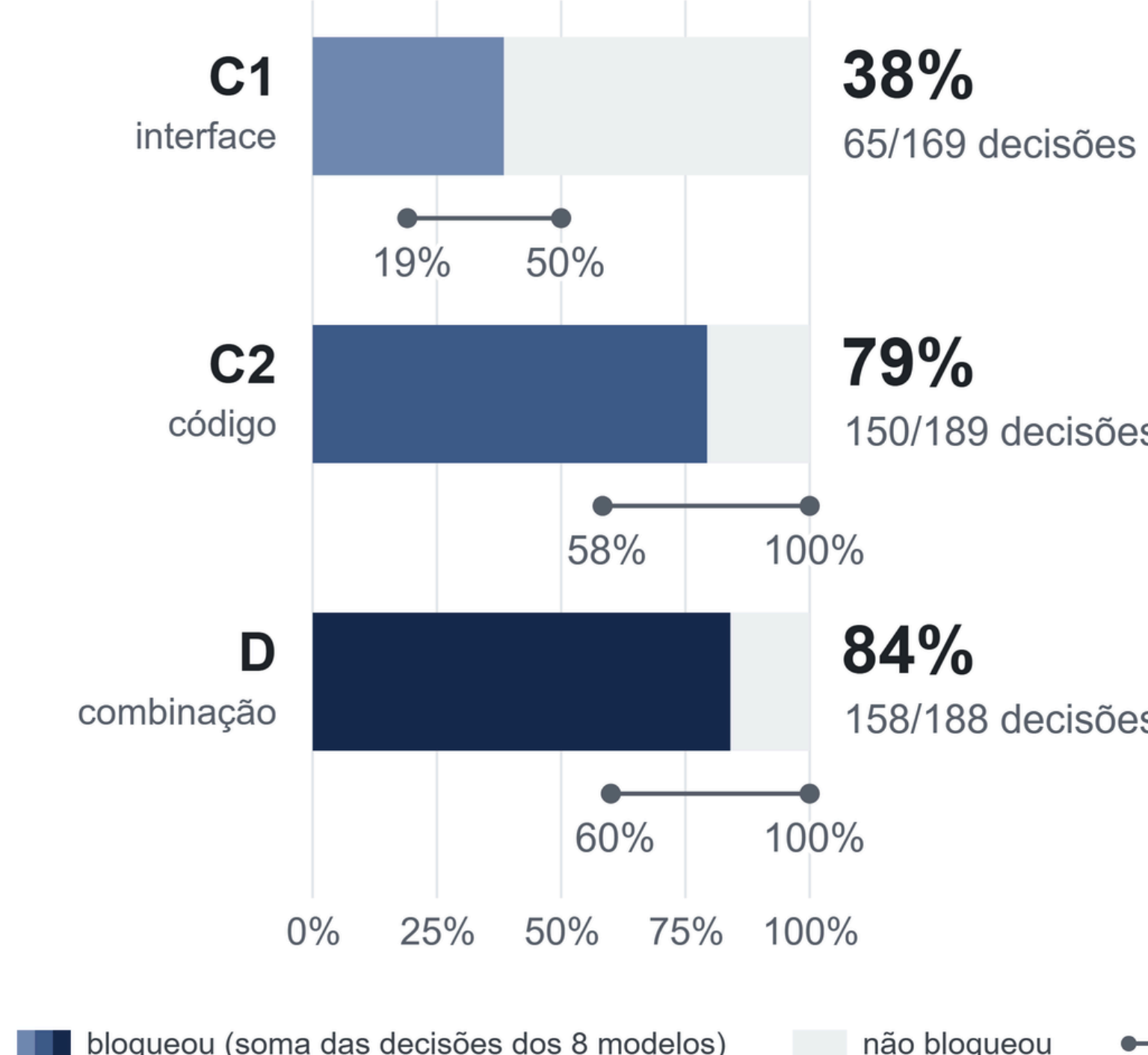
RESULTADOS PRINCIPAIS

MUDANÇAS PERIGOSAS

↑ quanto maior, melhor

Bloqueadas corretamente · N-INT · 12 casos

8 configurações • 2 repetições • percentuais sobre decisões válidas

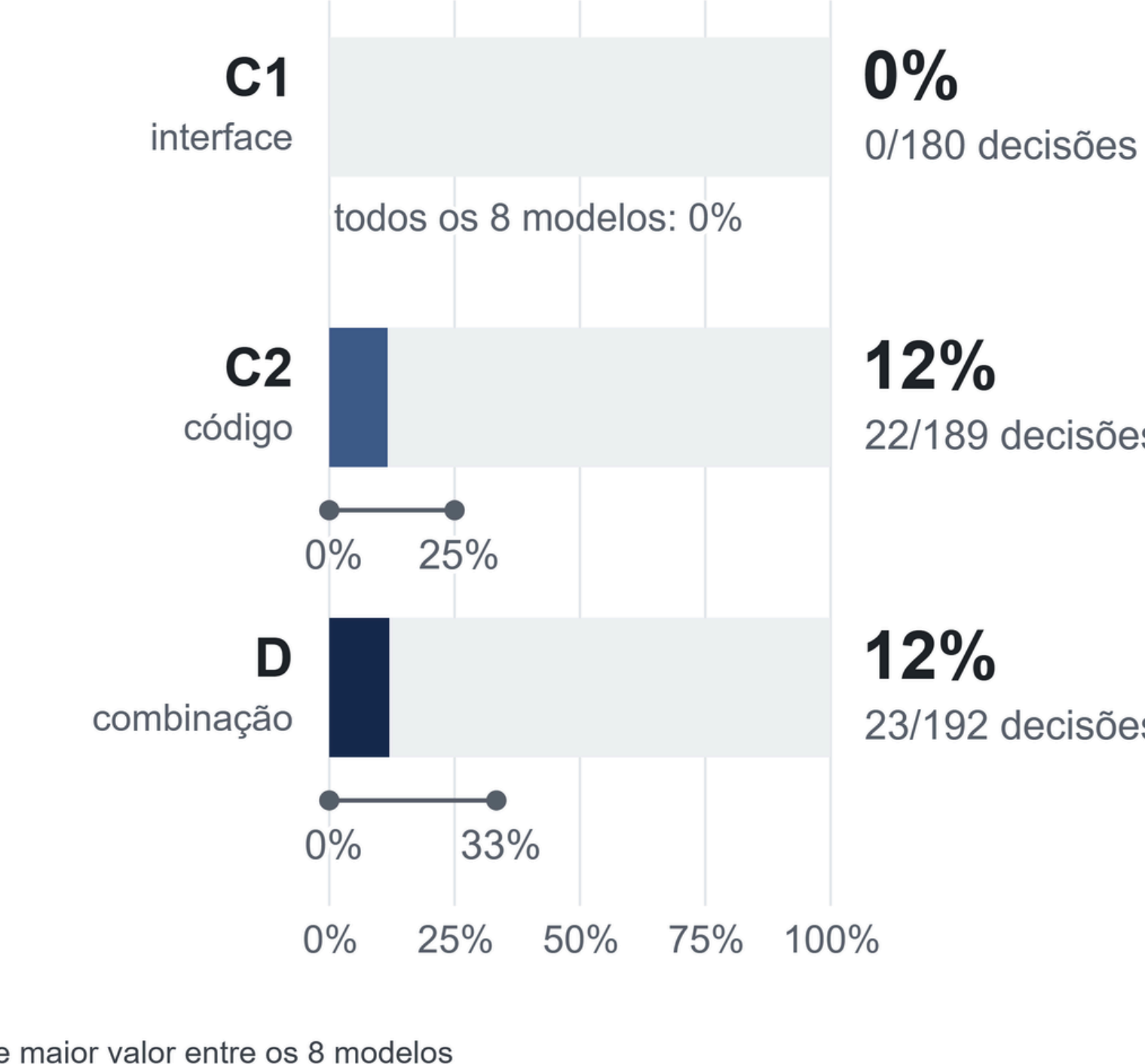


ATUALIZAÇÕES LEGÍTIMAS

↓ quanto menor, melhor

Bloqueadas por engano · N-INT · 12 casos

8 configurações • 2 repetições • percentuais sobre decisões válidas

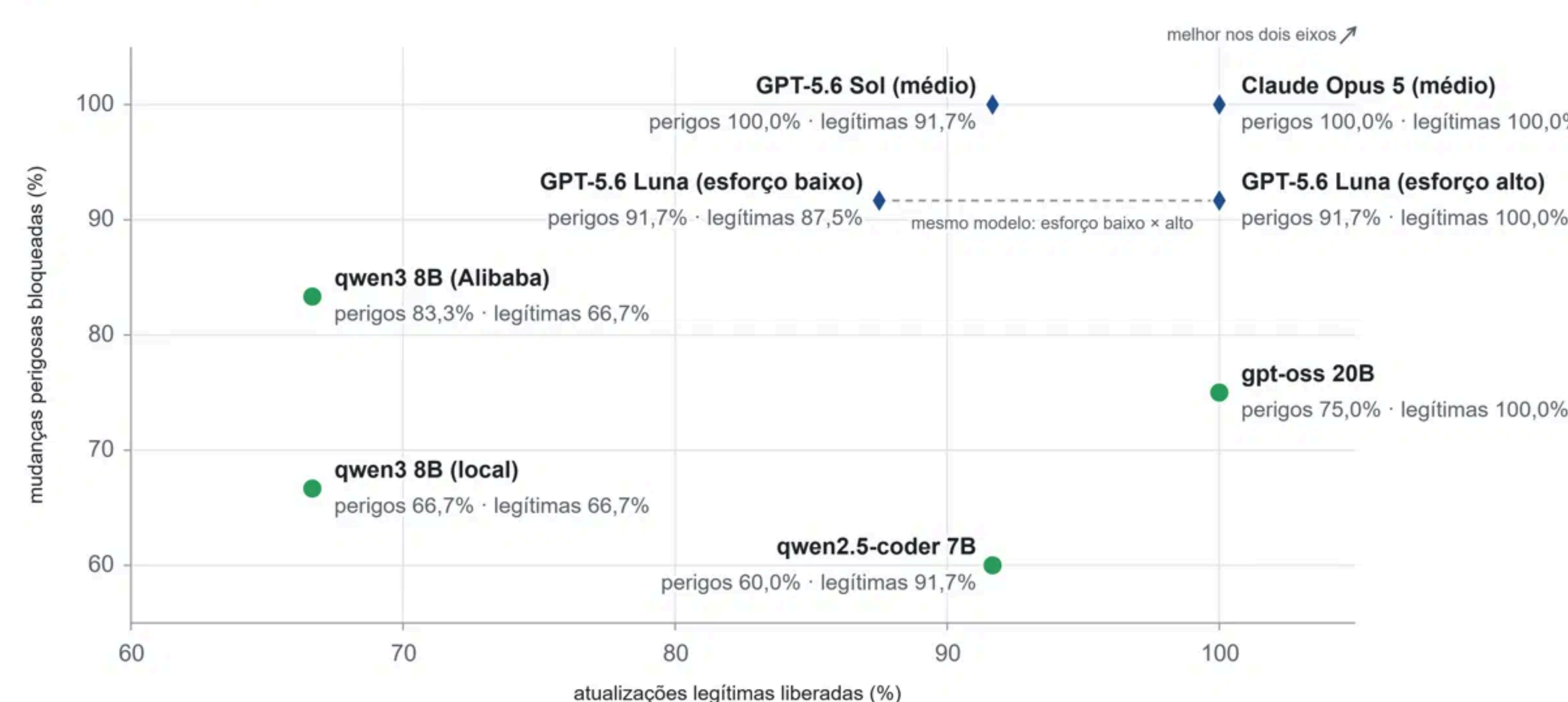


Fonte: Os autores (2026).

O resultado varia com o modelo

Condição D · N-INT

● modelos menores ◆ modelos de fronteira



Fonte: Os autores (2026).